MITRE ATLAS | AML.CS0036 - AIKatz: Attacking LLM Desktop Applications

Entry Information

ID:
AML.CS0036

Type:
Case-Study

Name:
AIKatz: Attacking LLM Desktop Applications

URL:
https://atlas.mitre.org/studies/AML.CS0036/

Incident Date:
2025-01-01

Target:
LLM Desktop Applications (Claude, ChatGPT, Copilot)

Actor:
Lumia Security

Description

Researchers at Lumia have demonstrated that it is possible to extract authentication tokens from the memory of LLM Desktop Applications. An attacker could then use those tokens to impersonate as the victim to the LLM backed, thereby gaining access to the victim's conversations as well as the ability to interfere in future conversations. The attacker's access would allow them the ability to directly inject prompts to change the LLM's behavior, poison the LLM's context to have persistent effects, manipulate the user's conversation history to cover their tracks, and ultimately impact the confidentiality, integrity, and availability of the system. The researchers demonstrated this on Anthropic Claude, Microsoft M365 Copilot, and OpenAI ChatGPT.

Vendor Responses to Responsible Disclosure:
- Anthropic (HackerOne) - Closed as informational since local attack.
- Microsoft Security Response Center - Attack doesn't bypass security boundaries for CVE.
- OpenAI (BugCrowd) - Closed as informational and noted that it's up to Microsoft to patch this behavior.

Attack Procedure:
[AML.T0012] Valid Accounts: The attacker required initial access to the victim system to carry out this attack.
[AML.T0089] Process Discovery: The attacker enumerated all of the processes running on the victim's machine and identified the processes belonging to LLM desktop applications.
[AML.T0090] OS Credential Dumping: The attacker attached or read memory directly from `/proc` (in Linux) or opened a handle to the LLM application's process (in Windows). The attacker then scanned the process's memory to extract the authentication token of the victim. This can be easily done by running a regex on every allocated memory page in the process.
[AML.T0091.000] Application Access Token: The attacker used the extracted token to authenticate themselves with the LLM backend service.
[AML.T0047] AI-Enabled Product or Service: The attacker has now obtained the access required to communicate with the LLM backend service as if they were the desktop client. This allowed them access

to everything the user can do with the desktop application.

[AML.T0051.000] Direct: The attacker sent malicious prompts directly to the LLM under any ongoing conversation the victim has.

[AML.T0080.001] Thread: The attacker could craft malicious prompts that manipulate the context of a chat thread, an effect that would persist for the duration of the thread.

[AML.T0080.000] Memory: The attacker could then craft malicious prompts that manipulate the LLM's memory to achieve a persistent effect. Any change in memory would also propagate to any new chat threads.

[AML.T0092] Manipulate User LLM Chat History: Many LLM desktop applications do not show the injected prompt for any ongoing chat, as they update chat history only once when initially opening it. This gave the attacker the opportunity to cover their tracks by manipulating the user's conversation history directly via the LLM's API. The attacker could also overwrite or delete messages to prevent detection of their actions.

[AML.T0048.000] Financial Harm: The attacker could send spam messages while impersonating the victim. On a pay-per-token or action plans, this could increase the financial burden on the victim.

[AML.T0048.003] User Harm: The attacker could gain access to all of the victim's activity with the LLM, including previous and ongoing chats, as well as any file or content uploaded to them.

[AML.T0029] Denial of AI Service: The attacker could delete all chats the victim has, and any they are opening, thereby preventing the victim from being able to interact with the LLM.

[AML.T0029] Denial of AI Service: The attacker could spam messages or prompts to reach the LLM's rate-limits against bots, to cause it to ban the victim altogether.

References

- AIKatz – All Your Chats Are Belong To Us — https://www.lumia.security/blog/aikatz